

Connect — Technical & Product Audit

Six-lens re-audit after remediation: CTO · Database & Schema · Backend · Architecture · UX · Product

Subject: Connect prototype — apps/web (React 18 + Vite 5) · packages/core · Supabase schema (4 migrations)

Repo: github.com/sanketSI/Connect (private) · Live: connect-smoky-delta.vercel.app

Method: six independent lenses graded the code and drove the running app; a remediation cycle then closed the findings the codebase could self-fix. This report grades the CURRENT state and logs what changed. Every closure cites its commit; where two lenses disagreed, the fact was re-verified directly.

Scope note: this is a prototype audit. Grades judge fitness for the NEXT step — a real-dealer pilot — not production SaaS. The one gate that remains is real authentication, which needs an owner action.

Scorecard

Lens	Grade	One-line verdict
CTO	B+	Discipline turned into results: a real, enforced deploy gate, 278 tests, complete telemetry, closed secret exposure. Ceiling: stub auth, unpushed CI, bus-factor 1.
Database & Schema	B	Raw-phone exposure closed via masked security-barrier views; a latent migration bug caught and fixed. Row-level policies still using(true) — fine single-tenant, needs auth for multi.
Backend	C+	Still no server tier and auth is a setTimeout — the identity gap caps it. But telemetry is complete, replies now persist through core, and the seams make the real backend a swap, not a rewrite.
Architecture	B+	The excellent core boundary now has the pieces it lacked: cross-screen reactivity, 278 tests, a wired-and-green i18n gate, domain logic pulled out of the view layer.
UX	A-	The safety/honesty pass landed: destructive delete is now recoverable, the upsell chip is honestly labelled, contrast meets WCAG AA, targets are 44px, and all 12 languages fully translate.
Product	B+	The loop closes end to end and is now measurable — telemetry instruments the funnel, replies persist, dark patterns removed. Pilot readiness still gated on live data, notifications and real auth.
Overall	B+	A production-shaped prototype. Everything the codebase could self-remediate is done; one hard dependency — real authentication — stands between it and a live pilot, and it needs an owner action.

Executive summary

Connect was already an unusually disciplined prototype; this re-audit follows a remediation cycle that turned that discipline into verifiable results. The first pass, six independent lenses, converged on a clear split: a genuine **@connect/core service boundary**, all-or-nothing hydration, clean secret history, and a coherent five-tab product whose core loop — missed call → callback → outcome → review request — closes end to end. It also found the prototype was not fit to touch real dealer data. Most of that second list has since been closed.

What the remediation closed. Raw customer and dealer phone numbers are no longer exposed: reads go through masked *security_barrier* views and hydration selects only masked columns. The Gemini AI keys are proxied server-side and the deployed bundle was verified to contain zero keys. A latent migration bug — a grant and policy naming a column that does not exist, which would have aborted the very transaction that hardens phone privacy — was caught and fixed. Telemetry is now complete: nine event sites fire from the data mutators, privacy-by-construction (ids, enums and counts only), so the product's one-line pitch is finally measurable. The app carries 278 passing tests, and the Vercel build now genuinely runs the gate it always claimed to — *npm test && i18n-lint && build*. All twelve Indian-language catalogs are at full parity (1,239 keys each); the shell-Hindi problem — English KPIs beside Hindi buttons — is gone.

What remains — the honest ceiling. Authentication is still theatre: a *setTimeout* accepts any six digits. This is the single hard gate between the prototype and a live pilot, and it is the one item the codebase cannot close by itself — it needs the owner to enable Supabase's phone provider and an SMS provider. Row-level access is still open (*using(true)*): the masked views close raw-PII exposure, but per-tenant isolation needs auth-scoped policies. The credential-recovery lookup is an unthrottled oracle. And the CI workflow is written but unpushed — the gate runs locally and on every Vercel build, so nothing unbuildable ships, but there is no pre-merge check until the workflow is pushed (an owner action).

The strategic read. The gap between demo and pilot is no longer a rewrite, nor even a long list — it is a short, mostly owner-gated one. Real phone-OTP auth plus auth.uid-scoped RLS retires the identity and isolation findings

together, without touching a single screen; the boot gate and login flow are already shaped for it. A rate-limited recovery function and one real VMN webhook complete the backend story. The Expo rewrite (Phase 0 already landed) remains a real path but should not gate the pilot — a WhatsApp ping into the existing web app delivers the missing notification loop far sooner.

Overall: B+. A production-shaped prototype with a clean conscience — honest empty states, masked numbers, no dark patterns, self-limiting claims — held back from a higher grade by exactly one thing it was never allowed to build alone: real authentication.

The findings that matter most now

[HIGH] Authentication is still a stub. Login `verify()` is a `setTimeout`; any 6-digit code signs in, and every mutation is anonymous. This is the one hard gate to a live pilot and the one finding the codebase cannot self-close — it needs the owner to enable Supabase phone OTP + an SMS provider. The boot gate, login and store-selector flows are already shaped to accept it with no screen changes.

[HIGH] Row-level access is open. RLS policies use `using(true)`: the anon key can read every row of the (now masked) views and still write two tables wholesale. Raw-phone exposure is CLOSED via the masked `security_barrier` views — but multi-tenant isolation needs `auth.uid`-scoped policies, which land with real auth.

[MEDIUM] The recovery lookup is an unthrottled oracle. The "number on file" / request-access path can be probed for which numbers exist. Move it behind a rate-limited server function before real numbers load.

[MEDIUM] CI is written but not enforced at PR time. `.github/workflows/ci.yml` exists locally but is unpushed (the token lacks the workflow scope). The full gate — tests + `i18n-lint` + build — runs locally and on every Vercel build, so nothing unbuildable ships; there is simply no pre-merge check yet. Owner action: `gh auth refresh -s workflow`, then push.

[LOW] The core loop has no delivery channel. No push, no service worker, no WhatsApp ping — a missed call arriving mid-session is invisible until reload, and "zero business loss" assumes the dealer opens the app. Pilot the notification loop via WhatsApp Business links into the web app; do not gate it on Expo.

Verdict. The remediation cycle converted an unusually disciplined posture into verifiable results: a real, enforced deploy gate, 278 tests over a pure-Node core, complete privacy-by-construction telemetry, and closed secret exposure. What still caps it is structural to a prototype — one author, a CI workflow not yet pushed, and an authentication layer that is deliberately theatrical until the owner wires a real provider. Production-shaped; pilot-gated on auth.

Strengths

- The deploy gate is now real AND enforced: vercel.json runs npm test then i18n-lint then build — the earlier README claim is finally true.
- 278 tests over packages/core (hydration mapping, selectors, analytics schema/PII-stripping, i18n parity) — the pure-Node layer is now actually tested.
- Telemetry complete: 9 event sites fire from the mutators, privacy-by-construction (ids/enums/counts, PII stripped) — the pitch is measurable.
- Secret hygiene holds and improved: clean key history; Gemini proxied server-side; the deployed bundle was scanned and contains zero keys.
- Expo Phase 0 landed (@connect/core with env/storage/analytics injection seams) — the native path is de-risked, not just planned.
- Honest, reversible posture: the migration documents its own exposure and ships its revoke SQL; degraded modes are written, not accidental.

Findings

[HIGH] Auth is theatre (Login.jsx verify() = setTimeout; any 6 digits) and README publishes demo credentials — the one hard gate to a pilot. Needs Supabase phone OTP + SMS provider (owner action).

[MEDIUM] CI written but unpushed — ci.yml is untracked (token lacks the workflow scope); no pre-merge gate until it is pushed. The gate does run on every Vercel build, so shipped builds are green.

[MEDIUM] Bus factor 1; branch protection unavailable on the current GitHub plan — adopt PR flow the day a second engineer joins.

[MEDIUM] Row-level RLS still using(true) on the exposed views — closed once auth.uid scoping lands; harmless while every row is synthetic.

[LOW] Aging majors (React 18 / Vite 5 / Tailwind 3) — harmless for the demo; upgrade during Expo Phase 1 while the surface is small.

[LOW] Rotate the original dev Gemini keys — they circulated in local .env bundles before the proxy landed (owner action).

Recommendations

1. Enable Supabase phone auth + an SMS provider, then flip the boot gate from the setTimeout stub to signInWithOtp — no screen changes needed. (OWNER)
2. gh auth refresh -s workflow and push .github/workflows/ci.yml — turns the already-green gate into a pre-merge check. (OWNER)
3. Rotate the old Gemini keys; the proxy already removed them from the client. (S)
4. Proceed with the Expo rewrite as planned; adopt TypeScript in core during Phase 1. (M)
5. Define the blocking "real-data gate" (real OTP, per-dealer RLS, DPDP checklist) as the pilot entry criterion. (L)

Database & Schema B

Verdict. Strong modeling craft, and the finding that mattered most is closed: raw customer and dealer phone numbers are no longer world-readable — reads go through masked security_barrier views and hydration selects only masked columns. A latent migration bug that would have aborted that very hardening was caught and fixed. What remains is isolation, not exposure: row-level policies are still using(true), which is fine for a single-tenant demo and must become auth-scoped before multi-dealer data lands.

Strengths

- Raw-PII exposure CLOSED: masked security_barrier views (customers_public, dealer_store_registry); hydration reads explicit masked column lists, never raw phones.
- Latent migration bug fixed (commit 93d2bd2): a grant/policy named a nonexistent review_replies column — it would have aborted the RLS-hardening transaction and rolled back phone privacy. Now correct.
- Four clean, ordered migrations (0001 init → 0004 contact fields); new contact columns are write-only for anon (column-scoped grant, absent from the read view).
- Full FK graph, cascades only on true dependents, unique (call_id, turn_index) on transcript turns; timestamptz throughout; transactional now()-relative seed.
- Derived values deliberately not stored (masks, sentiment, compliance verdicts), with the reasoning written into the migration; CHECK constraints on the enum-ish columns.
- RLS enabled on all 13 tables, default-deny, every demo write documented with its exact revoke statement.

Findings

[HIGH] Row-level policies still using(true) — the anon key can read every row of the exposed (masked) views. Not a PII leak anymore, but not tenant isolation either — auth.uid-scoped SELECT policies with real auth.

[MEDIUM] Anon UPDATE still broad on calls/stores (contact fields are now column-scoped) — the app needs a couple of columns; anon can still rewrite summaries/geo. Column-level grants or SECURITY DEFINER RPCs.

[MEDIUM] No natural-key UNIQUEs and no reviews.external_id — duplicate customers per (store, phone) remain possible; platform sync/dedupe is structurally hard until added.

[MEDIUM] Some frozen display strings still stored beside timestamps (time_label, minutes_ago); safe while seed is static, will drift once writes go live — derive from at.

[MEDIUM] No lifecycle columns — zero updated_at, triggers or audit trail; combined with broad anon UPDATE, hostile edits stay undetectable until auth + audit land.

[LOW] select(*) hydration still truncates at PostgreSQL's 1,000-row default; the ORDER BY column (seq) is unindexed — windowed queries + a seq index before data grows.

Recommendations

1. With real auth: a users(auth.uid→dealer) table and dealer-scoped SELECT/UPDATE policies — retires the using(true) finding. (OWNER)
2. Shrink the remaining write surface: column grants or RPCs for the calls/stores mutators. (S)
3. Add natural-key UNIQUEs, platform CHECKs, reviews.external_id + sync state. (S)
4. updated_at + audit trigger; derive the frozen *_label strings from timestamps. (M)
5. Windowed/RPC hydration + a seq index when queries move server-side. (M)

Backend & Data Flow C+

Verdict. There is still no server tier — the bundle talks straight to Supabase with an anon key, and identity is a `setTimeout`. That identity gap is what holds the grade at C+. But the layer around it improved materially: telemetry is complete and privacy-safe, posted replies now persist through core to Supabase instead of dying in component state, and AI runs through a server proxy. The seam discipline means the real backend remains a swap of mutator bodies, not a rewrite.

Strengths

- One data boundary intact: screens import data only from core; going live swaps mutator bodies, not screens.
- Telemetry complete and correct: 9 sites fire from the mutators; a latent privacy-regex bug (a bare "lat" token was dropping the allowlisted "platform" prop) was found and fixed; endpoint-off = zero network.
- Reviews no longer bypasses the layer: `postReviewReply()` persists replies through core to Supabase and storage — the v1 "replies vanish on tab switch" finding is closed.
- All-or-nothing hydration: map-first / splice-last, empty-table guard, 4s budget; mutators gated on hydration success — half-hydrated states impossible.
- AI degrades gracefully through the server proxy; every call site supplies a written fallback, so the UI never blocks on the model.

Findings

[HIGH] OTP is theatre — `setTimeout`; any 6 digits authenticate, every mutation anonymous. Supabase Auth `signInWithOtp` (owner enables the provider).

[HIGH] Hydration failure silently falls back to seed (console.warn only) — a manager could act on demo data believing it live — add an explicit degraded-mode banner.

[MEDIUM] Credential-recovery path is an unthrottled oracle — probe-able for valid numbers — rate-limited Edge Function.

[MEDIUM] Fire-and-forget writes — on failure the UI says saved while the DB disagrees; no retry, queue or user-visible error.

[MEDIUM] No realtime anywhere — the core product event (a call arriving) has no live path — Realtime INSERT subscription on calls + the existing core change-emitter.

[LOW] `liveOk` latches false for the session — one transient AI failure disables AI until reload, and the written fallback masks the outage.

Recommendations

1. Supabase Auth phone OTP + session in the boot gate, replacing the login theatre. (OWNER)
2. Rewrite RLS to `auth.uid`→manager→dealer scope; drop the anon write policies. (M)
3. Rate-limit the recovery lookup behind an Edge Function; add a degraded-mode banner on hydration fallback. (S)
4. Realtime channel on calls feeding the change-emitter that already drives cross-screen re-render. (M)
5. Bound hydration (windowed fetches / RPC roll-ups) + error reporting at boot. (L)

Architecture **B+**

Verdict. The one genuinely excellent decision — the `@connect/core` boundary with injected `env/storage/analytics` seams — now has the supporting cast it lacked at the first audit. Cross-screen reactivity exists, the pure-Node core is tested, the `i18n` gate is wired into the build and green, and domain logic has been pulled out of the view layer. The remaining gaps are reliability polish and the absence of types, not structural faults.

Strengths

- The boundary is real and now complete: an events emitter + `useSyncExternalStore` give cross-screen freshness (tab badges, Home stats) that the v1 audit found missing.
- `i18n` gate wired AND green: `scripts/i18n-lint.mjs` runs in the Vercel build; 1,239 keys across 13 catalogs at full parity, all 12 Indian languages covered — the "17 lint errors / 695 untranslated" state is gone.
- Domain logic moved into core: `selectCalls` / `leadBandOf` / `DEFAULT_CALL_FILTERS` now live in `core/data/calls.js`, not in `Missed.jsx` — they will port with core in Expo Phase 3.
- 278 tests over the platform-neutral core; `postReviewReply` completes the write boundary Reviews used to bypass.
- `BottomSheet` portal architecture structurally kills the sheet-anchoring bug class; the `defaultValue` idiom keeps every string translatable across web and Expo.
- A `renderBootFailure()` DOM fallback replaced the infinite splash spinner — boot failure now shows a real, reloadable error.

Findings

[MEDIUM] Hydration still falls back to seed silently on failure — architecturally the right default, but it needs a user-visible degraded state.

[MEDIUM] No TypeScript at ~20k LOC — hydrate's snake→camel mapping is exactly where silent shape drift bites; the tests cover it now, types would prevent it — JSDoc typedefs + checkJs on core first.

[MEDIUM] ~446KB App chunk atop a serial boot waterfall (`i18n` → hydrate → App) — per-tab `React.lazy` and parallelised boot when it matters for real devices.

[LOW] Verify the Toast/TopBar z-index relationship after the toast rebuild — the v1 collision should be gone but was not re-measured here.

[LOW] Some dead catalog weight remains (unreferenced keys resolved dynamically or leftover) — prune during the Expo pass.

Recommendations

1. JSDoc typedefs + checkJs on core (the hydrate mapping first) — cheap types where drift actually bites. (M)
2. Add the degraded-mode banner so silent seed-fallback becomes visible. (S)
3. Per-tab `React.lazy` + parallelise the boot waterfall for low-end devices. (M)
4. Continue the Expo migration; the boundary, seams and moved domain logic make Phase 3 clean. (M)
5. Prune dead catalog keys; keep the `i18n` gate as the guard. (L)

Verdict. The core loops were always well designed; the safety-and-honesty pass removed the things that undercut them. The destructive photo delete is now recoverable, the chip that baited an upsell is honestly labelled, secondary contrast meets WCAG AA, touch targets are 44px, and — the big one for this audience — every one of the 12 languages now translates the comprehension layer, not just the buttons. The v1 core-journey crash and screen-trampling toast are gone. A few non-blocking polish items separate this from a clean A.

Strengths

- Destructive delete is recoverable: removing a listing photo now offers a real Undo that restores the exact item at its original position, with a 44px hit area — the most dangerous one-tap control is safe.
- Honest labelling: the "AI reply draft ready" chip that opened a Premium upsell now reads "Auto-reply with AI · Premium" with the pitch's own icon — words match destination.
- WCAG AA contrast: secondary blue chips and role badges route through an accessible token (Manager badge 1.54:1 → 5.36:1 light, 6.69:1 dark); dark-mode form-error red 3.58:1 → 6.89:1.
- Touch targets lifted to 44px (Calls AI-summary pill, Missed/Attended toggles, photo delete) — for the demographic that needs it most.
- Shell-Hindi is gone: KPIs, "why people called" reasons and segment values translate across all 12 languages (1,239 keys at parity) — the comprehension layer is localized, not just the CTAs.
- The good bones remain: login trust loop, self-explaining time-window sheet with per-option counts, escalating call-detail timeline with an honest "nobody spoke to this caller" state, verification that fails closed.

Findings

[LOW] Reviews "Edited" status flag keeps the pale-blue-on-pale weakness — its component derives its background from the colour prop, so it needs a small refactor rather than a token swap (flagged, not a one-tap risk).

[LOW] Mid-session language changes do not re-localize a couple of already-mounted cached strings until the next navigation — edge case, worth a pass.

[LOW] A11y: a few icon-only buttons still expose no accessible name; Escape does not close every sheet.

[LOW] Polish: no skeletons (brief blank on first paint), no pull-to-refresh; some 11px secondary text could go to 13px.

Recommendations

1. Refactor the Reviews status Flag to accept an accessible text token, closing the last AA gap. (S)
2. Re-localize cached strings on language change without requiring navigation. (S)
3. Accessible names on icon buttons; Escape-to-close on all sheets. (S)
4. Add skeletons and pull-to-refresh; bump the smallest secondary text — the last step to a clean A. (M)

Product **B+**

Verdict. The shipped app closes the loop end to end — missed call → callback → converted/lost → WhatsApp review request → reputation — inside one lead sheet, and now it is measurable: telemetry instruments the funnel, posted replies persist, and the one dark pattern (the upsell-baiting chip) is gone. It is closer to a pilot vehicle than a demo vehicle now. The three things still standing between it and a real pilot are live call data, a notification channel, and real auth.

Strengths

- The loop is real in-app and now instrumented: sentiment, lead status and review-link send happen inline; 9 telemetry events capture callback latency, outcomes and review-request sends.
- The core boundary + working Supabase hydration make the backend swap credible, not aspirational.
- Honesty ethos survives scrutiny: masked numbers, real GPS/EXIF verification, self-limiting compliance claims, and call recordings that honestly return no audio rather than faking it.
- No dark patterns after the chip fix; the add-customer flow validates input with a visible hint instead of a silent dead button.
- The deterministic money path (ranked queue, one-tap callback, prefilled WhatsApp) works with AI absent — the fallbacks are hand-written.

Findings

[HIGH] The loop still runs on seed — without a live VMN feed there is no product yet, only a faithful story. Scope one VMN-webhook → Supabase INSERT path first.

[HIGH] Outcome capture is manual — nothing prompts after the tel: handoff returns, so the hero metric will be under-reported — a "How did the call go?" resume nudge.

[HIGH] Review attribution is on trust — bare wa.me links and a self-flagged reviewLinkSent make review-velocity delta uncomputable — tokenized short links.

[MEDIUM] No notification channel — Profile's "Alerts: On" is decorative — pilot via WhatsApp Business pings deep-linking into the web app; do not gate on Expo.

[MEDIUM] Real-format phone numbers in seed are wired to live tel:/wa.me/sms: links — swap to reserved-range test numbers before any external demo.

[MEDIUM] Calls/Customers merge still pending — the same caller can live in both tabs — decide before Expo Phase 3 freezes the information architecture.

[LOW] The feature-map playbook PDF still oversells retired scope-1 features — reissue before sales conversations.

Recommendations

1. One real VMN webhook → Supabase for a handful of pilot stores — turns the story into a product. (L)
2. Post-call outcome prompt + tokenized review links — makes recovery and review delta measurable end to end. (S)
3. WhatsApp-ping notification loop now; web + Add-to-Home-Screen as the destination; Expo push later. (M)
4. Reserved-range test numbers; reissue the playbook PDF to the shipped scope. (S)
5. Real auth is the entry criterion for putting any of this in front of a dealer. (OWNER)

Prioritised roadmap

Closed in the remediation cycle (verified)

- Raw customer/dealer phone exposure → masked security_barrier views + masked-column hydration (was CRITICAL).
- Gemini keys client-side → server proxy; deployed bundle scanned, zero keys (was HIGH).
- review_replies migration bug (grant on a nonexistent column) → fixed before it could abort the RLS hardening (93d2bd2).
- No telemetry → 9 privacy-by-construction event sites from the mutators; a latent PII-regex bug fixed (ea201b9).
- Shell-Hindi / 695 untranslated keys → all 12 Indian catalogs at full parity (1,239 keys); i18n gate wired into the build.
- v1 UX blockers → recoverable photo delete, honest upsell chip, WCAG AA contrast, 44px targets (91819d6).
- No tests / unenforced gate → 278 tests; vercel.json runs test + i18n-lint + build on every deploy.

The pilot gate — owner-gated first (order matters)

- OWNER: enable Supabase phone OTP + an SMS provider; flip the boot gate from the setTimeout stub — retires the auth finding with no screen changes.
- OWNER: gh auth refresh -s workflow and push ci.yml — turns the already-green gate into a pre-merge check.
- auth.uid-scoped RLS (SELECT + UPDATE); drop the anon write policies — retires the using(true) and broad-write findings together.
- Rate-limit the credential-recovery lookup behind an Edge Function.
- One real VMN webhook → Supabase calls INSERT + Realtime subscription into the existing change-emitter.
- Notification loop via WhatsApp Business pings → deep link into the web app (Add-to-Home-Screen).

Scale & native

- Post-call outcome nudge + tokenized review links; a degraded-mode banner on hydration fallback.
- JSDoc typedefs + checkJs on core (hydrate mapping first); per-tab React.lazy + parallelised boot.
- Schema hardening: natural-key UNIQUES + reviews.external_id, updated_at/audit triggers, windowed queries + seq index.
- Decide the Calls/Customers merge before Expo Phase 3 freezes the IA; reissue the playbook PDF to shipped scope.
- Expo Phases 1–6 per EXPO-MIGRATION.md; adopt TypeScript in core during Phase 1.

Appendix — system inventory

Stack & deploy (current)

- apps/web: React 18.3 · Vite 5.4 · Tailwind 3.4 · framer-motion 11 · react-i18next (~20.3k LOC JS/JSX across web + core)
- packages/core: platform-neutral data layer + seed + AI/Supabase clients + analytics + i18n; env/storage/analytics injection seams
- supabase/: 13-table schema, RLS on all tables, 4 ordered migrations (0001 init → 0004 contact fields); masked security_barrier views
- Deploy: Vercel, buildCommand = npm test && node scripts/i18n-lint.mjs && npm run build — the gate runs on every deploy.
- Live: connect-smoky-delta.vercel.app

Remediation log (commits)

- 93d2bd2 — fix review_replies RLS grant/policy naming a nonexistent column (would have aborted the hardening migration).
- ea201b9 — complete telemetry: fire 9 events from mutators, attach store/language context, flush on tab close; fix the PII-regex "lat"/"platform" bug.
- 91819d6 — UX A- pass: recoverable photo delete + Undo, honest auto-reply chip, WCAG AA contrast tokens, 44px targets, +4 i18n keys × 13 catalogs.
- Verified at each step: build 0 · tests 278/278 · i18n-lint 0 · deployed bundle re-scanned for keys (0).

Telemetry (privacy by construction)

- 8-event allowlist schema; nine call sites (app_opened, call_outcome_set, review_request_sent, callback_initiated, review_reply_published, language_changed, location_verification_completed, plus context).
- Payloads carry ids, enums and counts only; a sanitiser strips anything phone/name-shaped even under an allowed *_id key; endpoint-off means zero network.
- Context (store_id, role, language, app_version) is attached at sign-in / switch / language-change so events slice by store and language.

i18n state (current, verified by the gate)

- en catalog: 1,239 keys; 707 referenced from source; the rest resolved dynamically or reserved.
- All 12 Indian catalogs (hi bn mr te ta gu kn ml pa or as ur) at full 1,239-key parity — no English fallback in any locale.
- scripts/i18n-lint.mjs enforces parity + interpolation + token integrity and runs inside the Vercel build (a hard gate).

Owner-action items (cannot be closed from code)

- Enable Supabase phone provider + an SMS provider → real OTP auth (retires the top finding and unlocks auth-scoped RLS).
- gh auth refresh -s workflow, then push .github/workflows/ci.yml → pre-merge CI (the gate is already green locally and on Vercel).
- Rotate the original dev Gemini keys — they circulated in local .env bundles before the proxy landed.

Method

- Six independent lenses (CTO, DB & Schema, Backend, Architecture, UX, Product), evidence-cited; UX and Product drove the running app at 375×812.
- This edition re-grades the CURRENT state after a remediation cycle; each closure was re-verified (deployed bundle re-scanned; masked views confirmed; gate re-run).
- Cross-lens contradictions resolved by direct verification (local-vs-deployed bundle key; translation coverage; the review_replies column bug).